

INFORMATION SECURITY POLICY

Version 1.0

Revision Date: July 23, 2026

Contact: security@prompthalo.com



DOCUMENT INFORMATION

Document Family	Governance, Ethics, and Security
Document Title	Information Security Policy
Document ID	POL-ISP-001
Current Version	1.0
Approved Date	July 23, 2026
Approved By	Information Security Steering Committee
Effective Date	July 23, 2026
Next Review Date	July 23, 2027
Classification	Internal
Document Owner	Chief Executive Officer — Accountable Party
Prepared By	Security Officer
Review Cycle	Annual, or upon material change
Supersedes	N/A
Audience	All personnel, including employees and contractors

APPROVERS AND OWNERS

Name	Role	Information Security Role	Signature	Date
Madhuri Chandoor	Approver	CEO and Founder		July 23, 2026
Praveen Sharma	Owner / Author	Fractional CISO/Security Officer		July 23, 2026

COMPLIANCE

This document supports the Security category (Common Criteria) of the AICPA Trust Services Criteria. Availability, Confidentiality, Processing Integrity and Privacy are not in scope for the current examination period. Where a subordinate policy or standard addresses criteria in those categories, that coverage is retained deliberately so a category can be added in a future period without redrafting and does not extend the scope of any examination. The categories in scope, the report type and the observation period are recorded by the Information Security Steering Committee before each period begins. Where required by a client contract, the Company implements the additional controls specified in the applicable Business Associate Agreement or Data Processing Agreement.

DOCUMENT VALIDITY

This document is valid only in its published electronic form in the PromptHalo Technologies policy repository. Printed or locally saved copies are uncontrolled and must be verified against the published version before use. This document is classified Internal and may not be distributed outside PromptHalo Technologies or its authorized clients without the written approval of the Security Officer.

TABLE OF CONTENTS

1 OVERVIEW AND PURPOSE	5
2 SCOPE	5
3 ROLES AND DEFINITIONS.....	5
4 TERMINOLOGY	5
5 SECURITY PROGRAM	6
6 POLICY FRAMEWORK	8
7 CONTROL ENVIRONMENT AND ACCOUNTABILITY	9
8 PROGRAM ASSESSMENT	10
9 EXTERNAL COMMITMENTS AND COMMUNICATION.....	12
10 ENFORCEMENT.....	13
11 EXCEPTIONS.....	13
12 REFERENCE	13
13 ANNEX A — CRITERIA MAPPING.....	14
14 DOCUMENT POLICY HISTORY.....	15

1 Overview and Purpose

PromptHalo Technologies (“the Company”) depends on the confidentiality, integrity, and availability of its information systems and the customer data entrusted to it. This Information Security Policy establishes the Company's overall security program, assigns ownership and accountability, and authorizes the subordinate policies, standards, and procedures that implement it. It is the charter document of the Company's SOC 2 compliance programs.

2 Scope

This policy applies to all personnel – employees and contractors, all Company-owned or Company-managed information systems, all customer and Company data in any form, and all locations from which Company business is conducted, including remote work environments.

This policy is written for a company of the Company's current size and is to be read that way. Unless a clause says otherwise, a requirement to record, review, assess or approve something is satisfied by a short, dated note attributable to the person who made it. No clause in this policy requires a meeting, a dedicated tool, a committee sitting, or a document that does not already exist, and no clause requires a person to be appointed who is not already employed or engaged. [SOC 2: CC1.2, CC5.3]

Where a review required by this policy finds that nothing has changed, recording that finding satisfies the requirement in full. A review that concludes 'no change' is a performed control, not a skipped one. [SOC 2: CC4.1, CC5.3]

3 Roles and Definitions

1. “The Company” refers to PromptHalo Technologies.
2. The CEO or, in their absence, the Security Officer (the “Accountable Party”) owns this policy, oversees its implementation and enforcement, and may delegate specific duties to a designee. [SOC 2: CC1.3]
3. The Information Security Steering Committee approves this policy and reviews it at least annually. [SOC 2: CC1.2, CC5.3]

4 Terminology

The following terms have the meanings given below wherever they appear in this policy.

1. **Accountable Party** — the CEO or, in their absence, the Security Officer, who owns this policy.
2. **Confidential information** — information classified Confidential or Restricted under the Data Classification Policy, including customer data.
3. **Control** — an activity, automated or manual, performed on a defined cadence that produces evidence it occurred.
4. **Deficiency** — a control that is absent, not operating as described, or not producing evidence.

5. **Information Security Steering Committee** — the Company's oversight body for information security. At the Company's current size, the Committee comprises the CEO, and every reference in this policy to a decision, approval, review or report of the Committee is satisfied by a dated written record made or confirmed by the CEO; a formal meeting is not required. The Committee's composition is reviewed as the Company grows, and additional members are appointed when an oversight member independent of security operations becomes available. [SOC 2: CC1.2, CC1.3]
6. **Personnel** — employees, officers, contractors, consultants, interns and temporary workers of the Company.
7. **Security Officer** — the individual accountable for day-to-day operation of the security program.
8. **Subservice organization** — a third party whose controls the Company relies upon and which is carved out of the Company's report.
9. **Significant change** — a change meeting the trigger criteria in the Risk Management Policy that requires risk reassessment.

5 Security Program

1. The Company shall operate a documented information security program aligned to the SOC 2 Trust Services Criteria, proportionate to the Company's size, risk profile, and contractual obligations. [SOC 2: CC3.1]
2. The Accountable Party is accountable for the design, operation, and continuous improvement of the security program and reports on its status to the Information Security Steering Committee at least quarterly. [SOC 2: CC1.3, CC2.2]
3. The Information Security Steering Committee comprises the CEO and the Security Officer. [SOC 2: CC1.2]
4. The Company acknowledges that its current size prevents the appointment of an oversight member independent of security operations. As a compensating control, the CEO shall review the Security Officer's assessment of control effectiveness at least annually, and this limitation shall be recorded and reviewed in the risk register. [SOC 2: CC1.2]
5. That entry shall be a discrete item in the risk register, recorded as accepted with a compensating control, carrying a named owner and an annual review date. It is reviewed on that date whether the Company's size has changed, and the review is a single dated line in the register. [SOC 2: CC1.2, CC3.2]
6. The CEO shall record annually the basis on which they are able to review the Security Officer's assessment, being any combination of training completed, briefings received, or advice obtained from a qualified third party. Two or three sentences are sufficient, and the record may be made within the annual control environment assessment rather than separately. [SOC 2: CC1.2, CC1.4]
7. Decisions of the Information Security Steering Committee shall be recorded in writing, including the date and the persons taking the decision. A short-written note is sufficient; a formal meeting is not required. [SOC 2: CC1.2, CC4.2]

8. The Company shall maintain a Governance Decisions Log recording every Steering Committee approval, risk acceptance, policy exception and delegation of authority, together with its date, the person taking the decision, its scope and, where time-bound, its expiry. The Log is the record of governance decisions for the Company; meeting notes alone do not satisfy this requirement. [SOC 2: CC1.2, CC4.2]
9. The Information Security Steering Committee provides governance and oversight, approves security policies and material risk decisions, and reviews program performance at least annually. [SOC 2: CC1.2]
10. The composition of the Information Security Steering Committee shall be reviewed at least annually against a defined trigger. An oversight member independent of security operations shall be appointed when the Company exceeds 30 personnel, or upon the appointment of an independent director or advisor, whichever occurs first. The outcome of the review shall be recorded in the Governance Decisions Log even where no change is made. [SOC 2: CC1.2]
11. Any delegation by the Accountable Party of duties assigned to it under this policy shall be recorded in the Governance Decisions Log with the delegate, the scope of the delegation and its duration. Where no delegations are in force, that shall be recorded affirmatively at the annual review. [SOC 2: CC1.3]
12. Security objectives shall be established annually and measured through defined metrics, including control operating effectiveness, incident trends, vulnerability remediation timeliness, and training completion. [SOC 2: CC3.1, CC4.1]
13. The several annual confirmations, reviews and assessments required by this policy may be performed as a single exercise on one date each year and recorded in one document. Nothing in this policy requires them to be performed separately or on different dates, and performing them together is the expected approach at the Company's current size. [SOC 2: CC4.1, CC1.2]
14. Each security objective shall record the control or controls through which it is delivered, so that a control failure can be traced to the objective it places at risk. This is a field on the control matrix; no separate document is required. [SOC 2: CC3.1, CC5.1]
15. The Company shall maintain a single register of the external obligations to which it is subject, including applicable laws and regulations, contractual obligations, and commitments made to customers. The register is owned by the CEO, is reviewed at least annually, and records for each obligation the control or controls through which the Company meets it. [SOC 2: CC3.1, CC2.3]
16. The Security Officer shall maintain a short list of the external sources the Company relies on for security information, including cloud provider security bulletins, subservice organization report updates, model provider terms changes and applicable regulatory notices, and shall confirm annually that each remains monitored. No separate review cadence is required; the confirmation is made in the annual assessment. [SOC 2: CC2.1, CC3.4]

6 Policy Framework

1. This policy authorizes the subordinate policies and standards listed in Annex A. Annex A records, for each document, its identifier, title, current version, approval date, owner, and the Trust Services Criteria it addresses. No security policy or standard is effective unless it is recorded in Annex A. [SOC 2: CC5.3]
2. All security policies and standards shall be approved by the Information Security Steering Committee, reviewed at least annually, and communicated to personnel upon hire and upon material change. Personnel shall acknowledge the policies applicable to their role, and the acknowledgement record shall identify the individual, the document version and the date. [SOC 2: CC5.3, CC2.2]
3. Every document listed in Annex A, including the Code of Conduct, is published in the policy repository with its approval date and version recorded, and personnel are notified on issue. The notification record identifies the documents, their versions and the date; a single message covering several documents at once is sufficient. [SOC 2: CC1.1, CC2.2, CC5.3]
4. Standards and procedures that implement these policies are maintained by the Security Officer and kept current with the Company's technology and threat environment. The standards tier specifies platform, technology and configuration level requirements and is authorized by this policy through Annex A. [SOC 2: CC5.3]
5. The registers and records required by this policy are maintained as separate controlled documents and are not reproduced in this policy. They are: the Governance Decisions Log and the risk register, under the Risk Management Policy; the obligations and customer commitments register, maintained by the Security Officer; the control matrix, being the Common Criteria Control Plan; the Annual Control Environment Assessment at FRM-CE-001; and the plan of action under Section 8. The contents, format, custody and retention of each are defined in the document itself, and this policy does not restate them. [SOC 2: CC2.1, CC5.3]
6. Each document named above is recorded in Annex A with its owner, and a change to any of them does not require a change to this policy. [SOC 2: CC5.1, CC5.3]
7. Records required by this policy may be kept in the systems the Company already operates, including the code repository, the ticketing system, the compliance platform and dated electronic mail. A dated entry attributable to a named person is sufficient evidence; a signature, a form or a separate register is required only where a clause expressly says so. [SOC 2: CC2.1, CC5.3]
8. Risk assessment, including consideration of fraud risk and reassessment upon significant change, is governed by the Risk Management Policy. Personnel competence, screening and onboarding are governed by the Human Resources Security Policy, and security awareness training by the Security Awareness and Training Policy. Vendors, subservice organizations and complementary user entity controls are governed by the Vendor Management Policy. [SOC 2: CC1.4, CC3.2, CC3.3, CC3.4, CC9.2]

9. Control activities are selected and deployed in response to risks identified in the risk assessment. The relationship between assessed risks and implemented controls is maintained in the control matrix owned by the Security Officer, which records for each control its owner, operating frequency, the criterion it addresses and the evidence it produces. [SOC 2: CC5.1, CC5.2]
10. The control matrix shall record a named individual as the owner of each control, not a role alone. Where a role is held by more than one person, the individual accountable for the operation of the control shall be identified. Annex A records the owning document and the accountable role; the control matrix records the person. [SOC 2: CC1.5, CC5.1]
11. Control selection shall consider whether an activity prevents or detects the risk it treats, and the control matrix shall record which. Where a risk is addressed by detective controls only, that shall be recorded as such and reviewed at the annual risk assessment. [SOC 2: CC5.1]
12. Annex A maps each Trust Services Criterion in the declared scope to the document that owns it and to the named control owner. Every criterion in scope has at least one owning document. Annex A is reviewed at each annual policy review and whenever a policy or standard is issued or withdrawn. [SOC 2: CC5.1, CC5.3]

7 Control Environment and Accountability

1. Security responsibilities shall be defined for all roles, communicated in writing, and acknowledged by personnel as a condition of employment or engagement. [SOC 2: CC1.3, CC1.5]
2. The Company shall maintain a current organisation chart showing reporting lines and including contractors and any fractional officer. One page is sufficient. It is reviewed at the annual policy review and whenever a person joins or leaves, and where nothing has changed that shall be recorded. [SOC 2: CC1.3]
3. The Company defines the competencies required for each role, including its security responsibilities, and screens personnel and contractors proportionately to those responsibilities before granting access to production systems or customer data. All personnel complete security awareness training at onboarding and at least annually thereafter, and completion is tracked and reported to the Information Security Steering Committee. [SOC 2: CC1.4]
4. The periodic review of each person shall include their security and control responsibilities. Where the Company operates no formal performance cycle, a dated note from the CEO confirming that each person's control responsibilities were discussed and are being met satisfies this requirement. [SOC 2: CC1.5]
5. Segregation of duties shall be applied where practicable; where Company size prevents full segregation, compensating controls such as independent review and enhanced logging shall be documented. [SOC 2: CC5.2, CC6.3]
6. The application of segregation of duties shall be assessed at least annually and recorded. The assessment identifies each pair of conflicting duties held by a single person and states, for each, the compensating control relied upon and who performs it. A conclusion that full segregation is

not practicable at the Company's current size is acceptable where the compensating control is named; an absent assessment is not. [SOC 2: CC1.3, CC5.2]

7. The same assessment shall consider whether any individual holds more control responsibilities than they can reasonably discharge. Where a concentration is accepted, the compensating measure shall be named, being a reduced operating frequency, reassignment of specific controls, or external support. This is recorded in the same note as the segregation of duties assessment and requires no separate exercise. [SOC 2: CC1.5, CC1.3]
8. Personnel shall report suspected security weaknesses, policy violations, and incidents to the Security Officer in accordance with the Incident Response Plan. [SOC 2: CC2.2, CC7.3]
9. Standards of behavior and ethical values expected of personnel are set out in the Code of Conduct, which personnel acknowledge upon hire, upon material revision, and at least annually thereafter as a condition of employment or engagement. [SOC 2: CC1.1]
10. Concerns regarding the conduct of the Security Officer, or which a person prefers not to raise with the Security Officer, may be reported directly to the CEO. The Company prohibits retaliation against any person who makes a report in good faith. [SOC 2: CC1.1, CC2.2]
11. Such reports may be made to the ethics reporting address published in the Code of Conduct, which is delivered only to the CEO. Reports may be made without identifying the reporter. [SOC 2: CC1.1, CC2.2]

8 Program Assessment

1. The security program shall be assessed at least annually through internal control self-assessments and, where contractually required, independent examinations such as SOC 2 audits. [SOC 2: CC4.1]
2. The scope and frequency of the evaluations required by this section shall be confirmed at each annual assessment and adjusted where the system boundary, the customer base, the technology or the applicable obligations have changed materially. Where nothing material has changed, that shall be recorded and the existing cadence continues unaltered. [SOC 2: CC4.1, CC3.4]
3. Control self-assessments shall not be performed solely by the person who operates the control. Where the Company's size prevents assignment to an independent assessor, the completed assessment shall be reviewed and signed by the CEO. [SOC 2: CC4.1]
4. The annual control environment assessment shall be recorded on the Annual Control Environment Assessment form (FRM-CE-001) maintained by the Security Officer, covering at minimum the composition and independence of the Information Security Steering Committee, the segregation of duties assessment required by Section 7, and the fraud risk considerations required by the Risk Management Policy. The completed assessment shall be reviewed and signed by the CEO, and that signature is the compensating control for the absence of an oversight member independent of security operations. [SOC 2: CC1.2, CC1.3, CC3.3]
5. Identified deficiencies shall be recorded in a plan of action with assigned owners and remediation dates, tracked to closure by the Security Officer. [SOC 2: CC4.2]

- 219 6. The plan of action maintained under this section is the single record of control deficiencies for
220 the Company. Deficiencies identified by any means, including control self-assessment,
221 independent examination, monitoring, vulnerability management, continuity testing and post-
222 incident review, shall be recorded in it. Subordinate policies shall record deficiencies and
223 corrective actions in this plan of action and shall not maintain a separate register. [SOC 2: CC4.2,
224 CC7.5, CC5.3]
- 225 7. This clause takes precedence over any provision of a subordinate policy or standard providing for
226 a separate deficiency register, corrective action list or remediation tracker. Those provisions are
227 superseded to that extent, no amendment to the subordinate documents is required for this
228 Section to take effect, and the position is corrected in each document at its next scheduled
229 review. [SOC 2: CC4.2, CC5.3, CC7.5]
- 230 8. A deficiency is closed only when the corrective action has been verified as effective and the
231 verification has been recorded, identifying who verified it and the date. Recording a corrective
232 action as performed does not close the deficiency. [SOC 2: CC4.2]
- 233 9. Failure to perform a scheduled control activity or evaluation by its due date is itself a deficiency.
234 It shall be recorded in the plan of action and escalated in the quarterly report, whether the
235 activity is subsequently performed. [SOC 2: CC4.2, CC5.3]
- 236 10. Deficiencies shall be assigned a severity and reported to the Information Security Steering
237 Committee in writing at least quarterly. Deficiencies remaining open beyond their agreed
238 remediation date shall be escalated in that report. [SOC 2: CC4.2]
- 239 11. The report required by this section shall be made in writing within 15 days of the end of each
240 quarter and shall cover control operating status, deficiencies opened and closed in the period,
241 deficiencies remaining open beyond their agreed remediation date, and the security metrics
242 established under Section 5. [SOC 2: CC2.2, CC4.2]
- 243 12. Where no deficiency was opened or remained open in the period and no incident occurred, the
244 report may state that fact in a single line together with the metrics. The report is required every
245 quarter; its length is not. [SOC 2: CC2.2, CC4.2]
- 246 13. The quarterly report shall identify deficiencies previously closed and since reopened. A deficiency
247 that recurs shall be escalated to the Information Security Steering Committee as a concern with
248 the design of the control, rather than remediated again on the same terms. [SOC 2: CC4.2]
- 249 14. The Company shall maintain a System Security Plan describing system boundaries, environments
250 of operation, and implemented controls. [SOC 2: CC2.1]
- 251 15. The boundary recorded in the System Security Plan as at the date of an assessment is the stated
252 scope of that assessment. The Risk Management Policy governs how each assessment is
253 performed; this clause fixes what it is performed against, so that the two documents cannot
254 describe different systems. [SOC 2: CC3.1, CC2.1]
- 255 16. Where a change moves the system boundary, closing that change includes updating the System
256 Security Plan and the asset inventory. Both artifacts already exist and the update is part of closing

the change, not a separate task; the Risk Management Policy and the Asset Management Policy govern the trigger and the inventory respectively. [SOC 2: CC3.4, CC2.1]

9 External Commitments and Communication

1. The security, availability and confidentiality commitments the Company makes to customers shall be recorded in the applicable customer agreement or data processing agreement. The Security Officer shall review these commitments annually against the controls in operation and report any divergence to the Information Security Steering Committee. [SOC 2: CC2.3]
2. The Company shall maintain a register of the commitments made to customers, identifying for each commitment the agreement in which it is made, the customer or customers to whom it is owed, and the control through which the Company satisfies it. The register shall be reviewed at least annually and upon each new or amended customer agreement and is maintained alongside the obligations register required by Section 5. [SOC 2: CC2.3]
3. The Company shall publish a monitored security contact address through which third parties may report security concerns and suspected vulnerabilities. Reports shall be triaged under the Incident Response Plan. [SOC 2: CC2.3]
4. The address shall be reachable without a customer relationship, published on the Company's public website and in a security.txt file at the conventional location, and vulnerabilities reported through it shall enter the same triage path as internally identified vulnerabilities. The Incident Response Policy governs the triage; this clause fixes that the route in is public. [SOC 2: CC2.3, CC7.1]
5. The Company shall maintain a current list of sub processors and third parties that process customer data, including providers of artificial intelligence services, and shall notify customers of material changes in accordance with its contractual commitments. [SOC 2: CC2.3, CC9.2]
6. That list shall be derived from the vendor inventory rather than maintained separately, shall be available to customers on request or published, and the Vendor Management Policy shall define the notification step and the notice period the Company gives before a material change takes effect. [SOC 2: CC2.3, CC9.2]
7. Obligations to notify customers following a security incident, including notification triggers and timeframes, are defined in the Incident Response Plan and in applicable customer agreements. [SOC 2: CC2.3, CC7.4]
8. Those triggers and timeframes shall be recorded in a single notification matrix maintained under the Incident Response Policy, covering the periods committed in customer agreements and those required by applicable law, and the shortest applicable period shall govern. Where the Company later issues a separate privacy policy, it shall reference that matrix rather than restate the periods. [SOC 2: CC2.3, CC7.4]
9. Security commitments to customers or prospective customers shall be reviewed by the Security Officer before they are made. [SOC 2: CC2.3]

10. That review shall be performed as a defined step in the engagement intake process and shall apply to every security questionnaire, proposal, published security claim and contractual commitment before it is issued. The reviewer, the item reviewed and the date shall be recorded. [SOC 2: CC2.3]

11. The Company uses the carve-out method for subservice organizations. Subservice organizations, their attestation reports, the controls the Company relies upon them to perform, and the complementary user entity controls the Company must itself operate are managed under the Vendor Management Policy. [SOC 2: CC9.2, CC2.3]

12. The Company shall also define the complementary user entity controls that its own customers are expected to operate and shall state where those controls are communicated to them. These are distinct from the complementary controls the Company operates for its subservice organizations; both sets are recorded under the Vendor Management Policy. [SOC 2: CC2.3, CC9.2]

10 Enforcement

1. Violations of this policy may result in disciplinary action up to and including termination of employment or engagement, and, where applicable, civil or criminal referral. [SOC 2: CC1.5]
2. The Security Officer documents the security finding and recommends action. The CEO determines and documents the disciplinary outcome, applies it consistently, and retains the personnel record. [SOC 2: CC1.5]
3. This split of responsibility applies wherever disciplinary action arises from a security matter, including action taken under the Human Resources Security Policy or the Code of Conduct. Comparable findings shall attract comparable outcomes, and the reason for any departure shall be recorded. [SOC 2: CC1.5, CC1.1]

11 Exceptions

Exceptions to this policy must be requested in writing to the Security Officer and approved by the Information Security Steering Committee before taking effect. Approved exceptions shall be recorded in the Policy Exception Register maintained by the Security Officer, capturing the requester, the policy and clause, the justification, the compensating control, the approver, the approval date and the expiry date. Exceptions shall be risk-assessed, time-bound, and reviewed at least annually. Where no exceptions are open, that shall be recorded affirmatively at the annual review. [SOC 2: CC5.3]

Where a requirement of this policy cannot be met proportionately at the Company's current size, the correct response is a recorded, time-bound exception with a named compensating control, not silent non-performance. An exception properly recorded is a functioning control; an unrecorded shortfall is a deficiency. [SOC 2: CC5.3, CC4.2]

12 Reference

1. SOC 2 Trust Services Criteria, Security category (CC1.1 through CC9.2)
2. POL-VM-001 Vendor Management Policy

3. POL-RSK-001 Risk Management Policy
4. FRM-CE-001 Annual Control Environment Assessment [SOC 2: CC1.2]
5. All subordinate policies and standards listed in Annex A
6. POL-AI-001 Artificial Intelligence Governance Policy [SOC 2: CC5.3]
7. POL-COC-001 Code of Conduct [SOC 2: CC1.1]

13 Annex A — Criteria Mapping

The following table maps each Trust Services Criterion in the declared scope to the document that owns it and to the named control owner. Where a criterion is addressed in more than one document, the primary owner is shown. Versions and approval dates are maintained in the policy repository index.

Criterion	Owning document	Control owner
CC1.1	POL-COC-001 Code of Conduct	Steering Committee
CC1.2	POL-ISP-001 Information Security Policy	Steering Committee
CC1.3	POL-ISP-001 Information Security Policy	Steering Committee
CC1.4	POL-HRS-001 Human Resources Security Policy	Steering Committee
CC1.5	POL-ISP-001 Information Security Policy	Steering Committee
CC2.1	POL-ISP-001 Information Security Policy	CEO
CC2.2	POL-SAT-001 Security Awareness and Training Policy	CEO
CC2.3	POL-ISP-001 Information Security Policy	CEO
CC3.1	POL-ISP-001 Information Security Policy	Steering Committee
CC3.2	POL-RSK-001 Risk Management Policy	CEO
CC3.3	POL-RSK-001 Risk Management Policy	CEO
CC3.4	POL-RSK-001 Risk Management Policy	CEO
CC4.1	POL-ISP-001 Information Security Policy	Steering Committee
CC4.2	POL-ISP-001 Information Security Policy	CEO
CC5.1	POL-RSK-001 Risk Management Policy	CEO
CC5.2	POL-AC-001 Access Control Policy	CEO
CC5.3	POL-ISP-001 Information Security Policy	CEO
CC6.1	POL-AC-001 Access Control Policy	CEO
CC6.2	POL-AC-001 Access Control Policy	CEO
CC6.3	POL-AC-001 Access Control Policy	CEO
CC6.4	POL-PHY-001 Physical Security Policy	CEO
CC6.5	POL-DRD-001 Data Retention and Disposal Policy	CEO

CC6.6	POL-NET-001 Network Security Policy	CEO
CC6.7	POL-ENC-001 Encryption Policy	CEO
CC6.8	STD-EPT-001 Endpoint Standard	CEO
CC7.1	POL-VPM-001 Vulnerability and Patch Management Policy	CEO
CC7.2	POL-LOG-001 Logging and Monitoring Policy	CEO
CC7.3	POL-IRP-001 Incident Response Policy	CEO
CC7.4	POL-IRP-001 Incident Response Policy	CEO
CC7.5	POL-IRP-001 Incident Response Policy	CEO
CC8.1	POL-CM-001 Change Management Policy	CEO
CC9.1	POL-BCP-001 Business Continuity and Disaster Recovery Policy	CEO
CC9.2	POL-VM-001 Vendor Management Policy	CEO

338

14 DOCUMENT POLICY HISTORY

Version	Date	Description
1.0	July 23, 2026	Initial policy release

339